# CYBER SECURITY REPORT

Threats, practices, and recommendations

REPORT PREPARED BY:
Mulumbwa Matimelo
Cyber Security Intern
Future Interns – Task 1 (2026)

## Executive Summary

A vulnerability assessment was conducted on Google Gruyere (gruyere.appspot.com), a deliberately vulnerable web application. The assessment used **passive, read-only techniques** including Nmap scanning and browser DevTools analysis.

### Key Findings

| Severity | Count | Issues |
|---|---|---|
| **HIGH** | 4 | Insecure cookies, admin exposure, path traversal, XSS |
| **MEDIUM** | 4 | Missing security headers, directory exposure |
| **LOW** | 2 | Information disclosure, console warnings |

### Critical Risks Identified

- Session cookies exposed in plaintext with missing security flags
- Admin panel accessible without proper authentication
- Path traversal vulnerability in snippet functionality
- Missing critical security headers

### Overall Security Rating: POOR

# Scope & Methodology

## Target Information

| Field | Details |
|---|---|
| **Target URL** | https://google-gruyere.appspot.com/5921884403014386940721792528355684807 19/ |
| **IP Address** | 142.251.216.20 |
| **Assessment Date** | March 31, 2026 |
| **Assessment Type** | Passive, read-only vulnerability assessment |

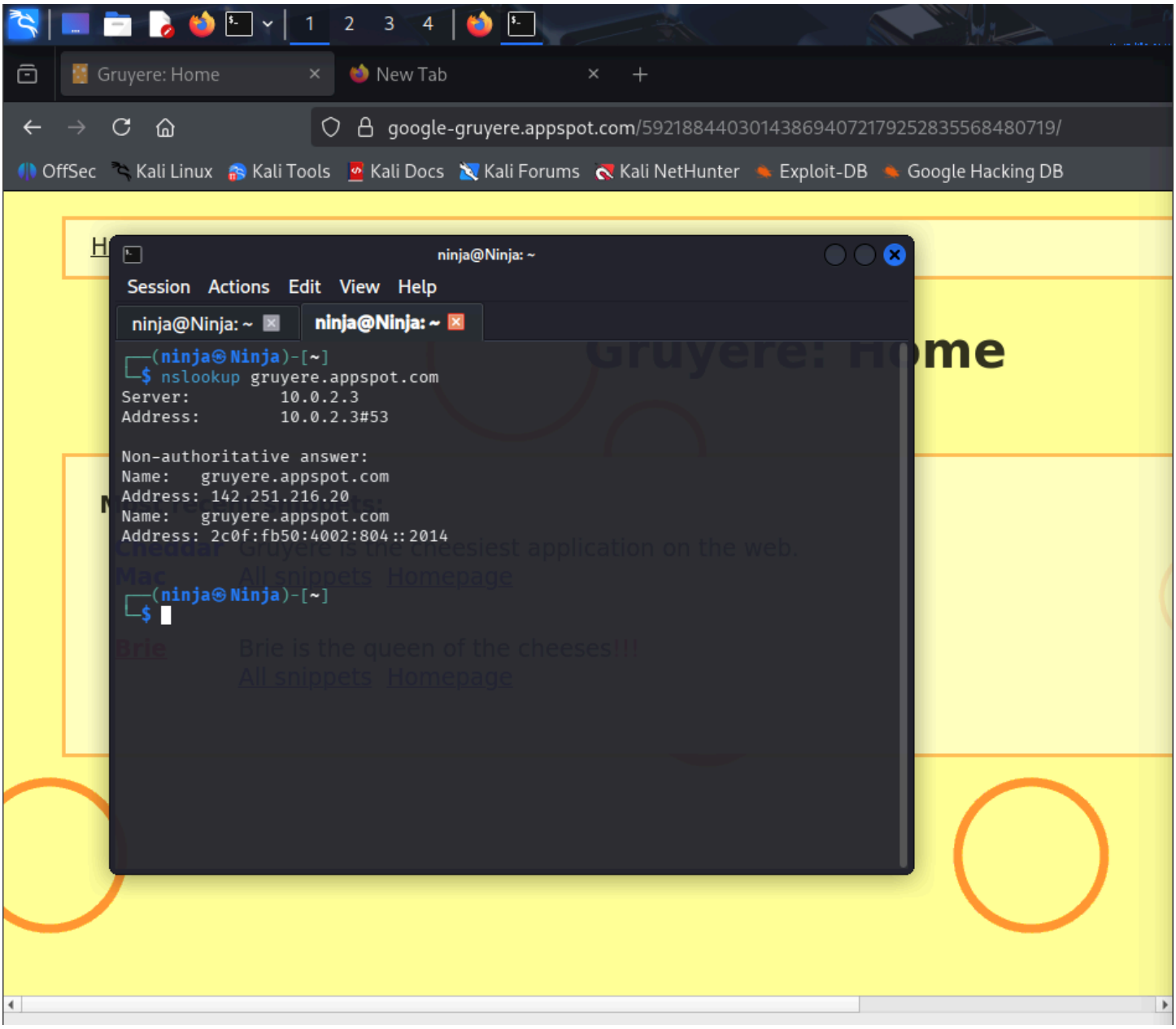
## Tools Used

| Tool | Purpose |
|---|---|
| **Nmap 7.95** | Port scanning and service detection |
| **Chrome DevTools** | Header analysis, cookie inspection, network monitoring |
| **Firefox DevTools** | Cross-browser verification |

## Ethical Boundaries

- Passive scanning only
- Public pages only
- No exploitation
- No login bypass attempts
- No Denial-of-Service

# Nmap Scan Results




## Port Scan Results

```
┌──(ninja㉿Ninja)-[~]
└─$ nmap -sV -Pn juice-shop.herokuapp.com

┌──(ninja㉿Ninja)-[~]
└─$ nmap -sV -Pn 142.251.216.20
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-31 13:12 EDT
Nmap scan report for lcjnbi-af-in-f20.1e100.net (142.251.216.20)
Host is up (0.018s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT    STATE SERVICE   VERSION
80/tcp  open  http
443/tcp open  ssl/https
2 services unrecognized despite returning data. If you know the service/versi
on, please submit the following fingerprints at https://nmap.org/cgi-bin/subm
it.cgi?new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port80-TCP:V=7.95%I=7%D=3/31%Time=69CC0081%P=x86_64-pc-linux-gnu%r(GetR
SF:equest,18C,"HTTP/1\.0\x20404\x20Not\x20Found\r\nContent-Length:\x20272\
SF:r\nContent-Type:\x20text/html;\x20charset=UTF-8\r\nDate:\x20Tue,\x2031\
SF:x20Mar\x202026\x2017:12:37\x20GMT\r\n\r\n\n<html><head>\n<meta\x20http-
SF:equiv=\"content-type\"\x20content=\"text/html;charset=utf-8\">\n<title>
SF:404\x20Page\x20not\x20found</title>\n</head>\n<body\x20text=#000000\x20
SF:bgcolor=#ffffff>\n<h1>Error:\x20Page\x20not\x20found</h1>\n<h2>The\x20r
SF:equested\x20URL\x20was\x20not\x20found\x20on\x20this\x20server\.</h2>\n
SF:<h2></h2>\n</body></html>\n")%r(HTTPOptions,18C,"HTTP/1\.0\x20404\x20No
SF:t\x20Found\r\nContent-Length:\x20272\r\nContent-Type:\x20text/html;\x20
SF:charset=UTF-8\r\nDate:\x20Tue,\x2031\x20Mar\x202026\x2017:12:37\x20GMT\
SF:r\n\r\n\n<html><head>\n<meta\x20http-equiv=\"content-type\"\x20content=
SF:\"text/html;charset=utf-8\">\n<title>404\x20Page\x20not\x20found</title
SF:>\n</head>\n<body\x20text=#000000\x20bgcolor=#ffffff>\n<h1>Error:\x20Pa
SF:ge\x20not\x20found</h1>\n<h2>The\x20requested\x20URL\x20was\x20not\x20f
SF:ound\x20on\x20this\x20server\.</h2>\n<h2></h2>\n</body></html>\n")%r(RT
SF:SPRequest,6B0,"HTTP/1\.0\x20400\x20Bad\x20Request\r\nContent-Type:\x20t
SF:ext/html;\x20charset=UTF-8\r\nReferrer-Policy:\x20no-referrer\r\nConten
SF:t-Length:\x201555\r\nDate:\x20Tue,\x2031\x20Mar\x202026\x2017:12:37\x20
```

Ports 80 and 443 are open. Port 80 returns 404 errors, while port 443 serves the application. The server is hosted on Google infrastructure.

# Detailed Findings

## Insecure Session Cookies (HIGH)

**Location:** All authenticated pages
**Risk Level:** **HIGH**

## Description

Session cookies lack critical security flags (HttpOnly, Secure) and expose sensitive user information in plaintext.

```
▼ Request Cookies
    GRUYERE: "35537955|milky||author"
    GRUYERE_ID: "5921884403014386940721792528355684807 19"
```

## Flags Check:

- HttpOnly: Missing

- Secure: Missing

- SameSite: Not set

## Information Exposed:

- User ID: 35537955

- Username: milky

- Role: author

## Impact

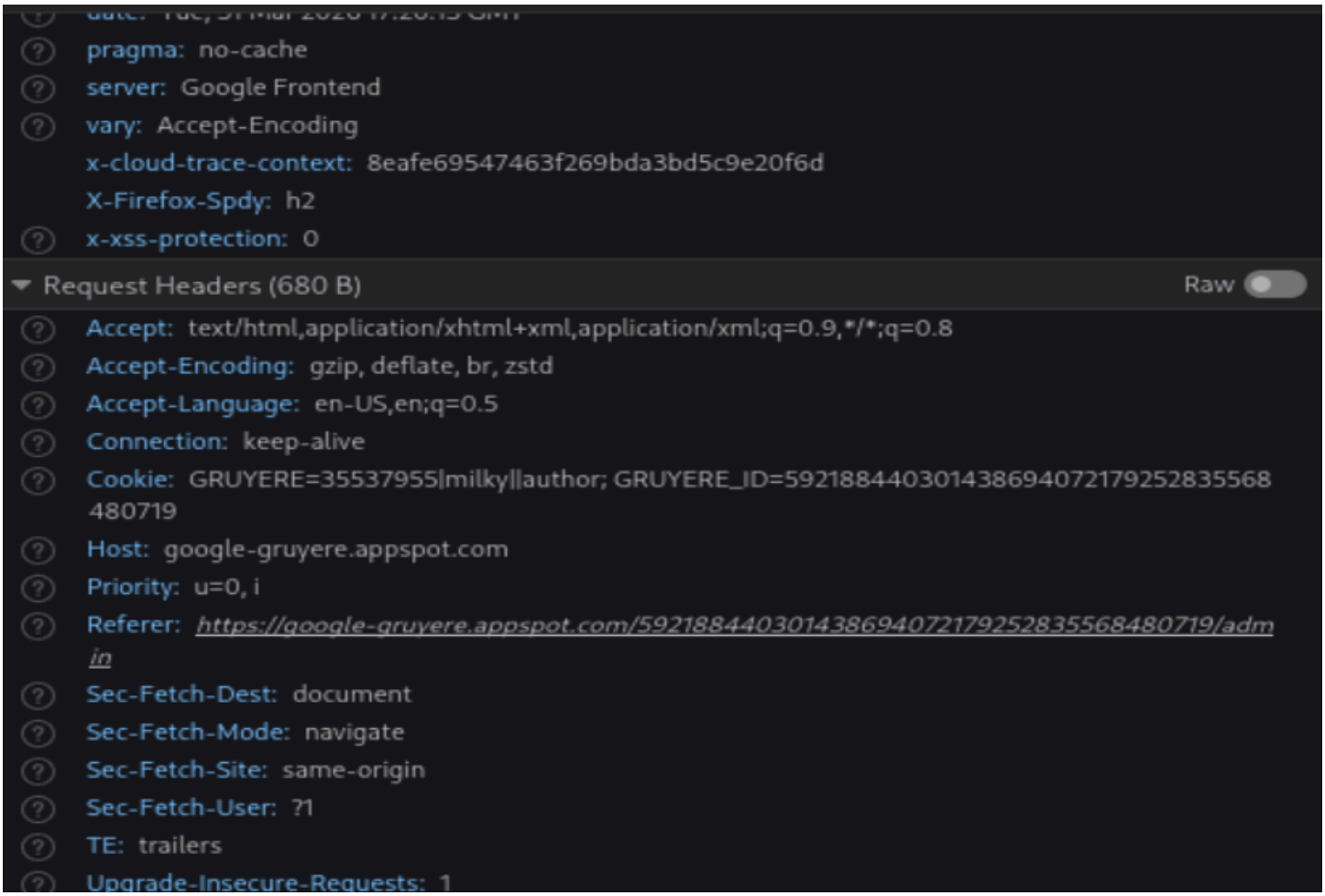
| Risk | Explanation |
|---|---|
| **Session Hijacking** | Cookies accessible via JavaScript (no HttpOnly) - XSS can steal sessions |
| **Man-in-the-Middle** | Cookies sent over HTTP (no Secure flag) |
| **Privilege Escalation** | Easy to modify cookie values (predictable format) |
| **Information Leak** | Username and role exposed to anyone viewing cookies |

## Admin Panel Exposure (HIGH)

**Location:** /admin endpoint
**Risk Level:** **HIGH**

## Description

The admin panel is accessible and was accessed during testing, potentially exposing administrative functionality.




## Impact

- Admin functionality exposed to non-admin users
- Potential privilege escalation
- Sensitive operations may be accessible
- Information disclosure about application structure

## Missing Security Headers (MEDIUM)

**Location:** All pages
**Risk Level:** **MEDIUM**

## Description

Critical HTTP security headers are missing from all responses, increasing attack surface.

Response Headers (369 B) Raw

```
alt-svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
cache-control: no-cache
content-encoding: gzip
content-length: 1302
content-type: text/html
date: Tue, 31 Mar 2026 17:26:13 GMT
pragma: no-cache
server: Google Frontend
vary: Accept-Encoding
x-cloud-trace-context: 8eafe69547463f269bda3bd5c9e20f6d
X-Firefox-Spdy: h2
x-xss-protection: 0
```

Request Headers (680 B) Raw

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Cookie: GRUYERE=35537955|milky||author; GRUYERE_ID=5921884403014386940721792528355684
480719
Host: google-gruyere.appspot.com
Priority: u=0, i
Referer: https://google-gruyere.appspot.com/5921884403014386940721792528355684480719/adm
```

## Impact

| | |
|---|---|
| Missing Header | Vulnerability |
| X-Frame-Options | Clickjacking attacks |
| X-Content-Type-Options | MIME-sniffing attacks |
| Content-Security-Policy | XSS attacks |
| Strict-Transport-Security | Protocol downgrade attacks |

## X-XSS-Protection Disabled (MEDIUM)

**Location:** All pages
**Risk Level:** **MEDIUM**

## Description

The X-XSS-Protection header is explicitly set to 0, disabling the browser's built-in XSS filter.

Response Headers (369 B) Raw

```
alt-svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
cache-control: no-cache
content-encoding: gzip
content-length: 1302
content-type: text/html
date: Tue, 31 Mar 2026 17:26:13 GMT
pragma: no-cache
server: Google Frontend
vary: Accept-Encoding
x-cloud-trace-context: 8eafe69547463f269bda3bd5c9e20f6d
X-Firefox-Spdy: h2
x-xss-protection: 0
```

Request Headers (680 B) Raw

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Cookie: GRUYERE=35537955|milky||author; GRUYERE_ID=5921884403014386940721792528355684
480719
Host: google-gruyere.appspot.com
Priority: u=0, i
Referer: https://google-gruyere.appspot.com/5921884403014386940721792528355684807 19/adm
```

## Impact

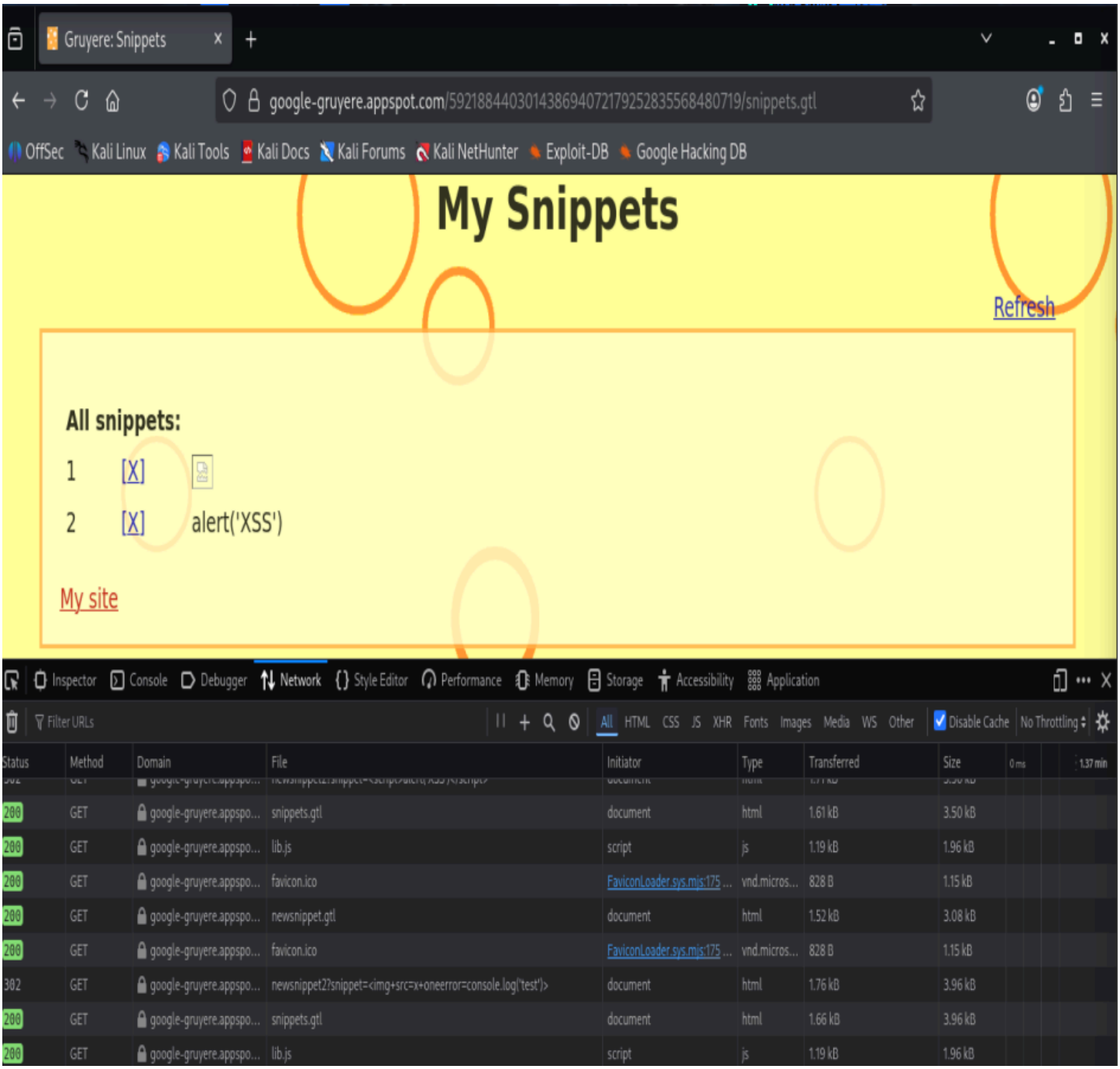
Browser's cross-site scripting filter is disabled, making users more vulnerable to XSS attacks. While modern browsers rely on CSP, this still removes an additional layer of protection.

## Path Traversal Vulnerability (HIGH)

**Location:** Snippet functionality (snippet.gtl)
**Risk Level:** **HIGH**

## Description

The snippet parameter may be vulnerable to path traversal attacks, allowing access to arbitrary files.




**Impact**

- Attackers can read arbitrary files
- Source code exposure
- Configuration file theft
- Potential credential disclosure

## Information Disclosure in Headers (LOW)

**Location:** All responses
**Risk Level:** **LOW**

## Description

Google Cloud trace ID exposed in response headers, revealing infrastructure details.

```
Response Headers (369 B)                                   Raw
    alt-svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
    cache-control: no-cache
    content-encoding: gzip
    content-length: 1302
    content-type: text/html
    date: Tue, 31 Mar 2026 17:26:13 GMT
    pragma: no-cache
    server: Google Frontend
    vary: Accept-Encoding
    x-cloud-trace-context: 8eafe69547463f269bda3bd5c9e20f6d
    X-Firefox-Spdy: h2
    x-xss-protection: 0
Request Headers (680 B)                                    Raw
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
    Accept-Encoding: gzip, deflate, br, zstd
    Accept-Language: en-US,en;q=0.5
    Connection: keep-alive
    Cookie: GRUYERE=35537955|milky||author; GRUYERE_ID=5921884403014386940721792528355684
    480719
    Host: google-gruyere.appspot.com
    Priority: u=0, i
    Referer: https://google-gruyere.appspot.com/5921884403014386940721792528355684807 19/adm
```

## Impact

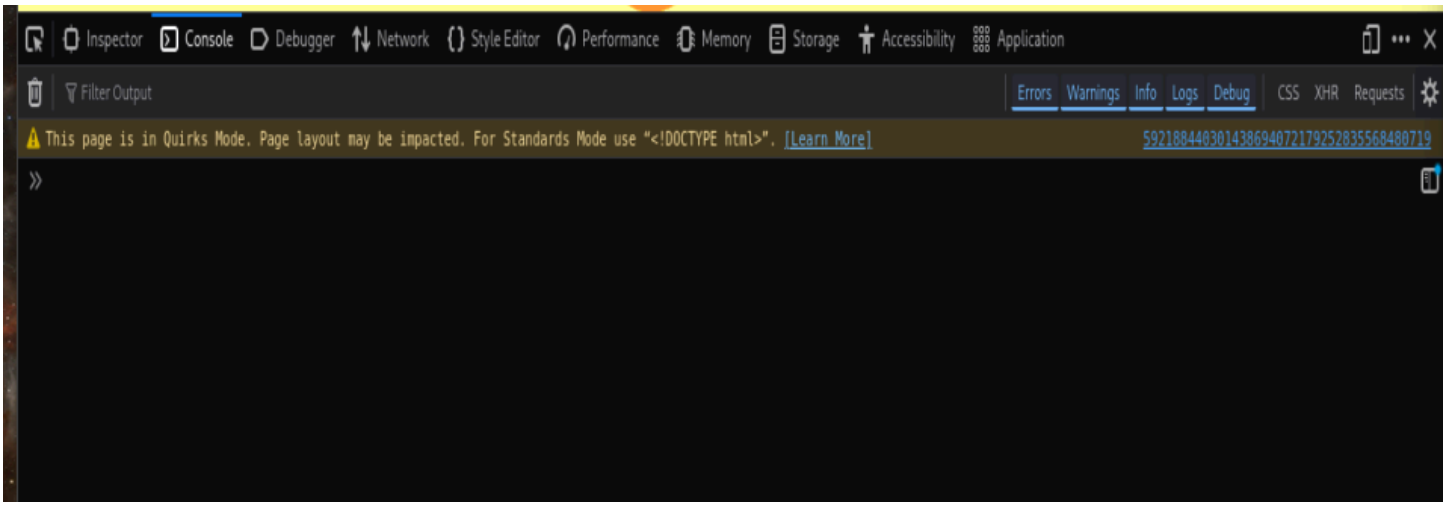
- Reveals use of Google Cloud infrastructure
- Can be used to correlate requests
- Minor information disclosure

## Console Errors / Quirks Mode (LOW)

**Location:** All pages
**Risk Level:** **LOW**

## Description

The page operates in Quirks Mode due to missing DOCTYPE declaration.




**Impact**

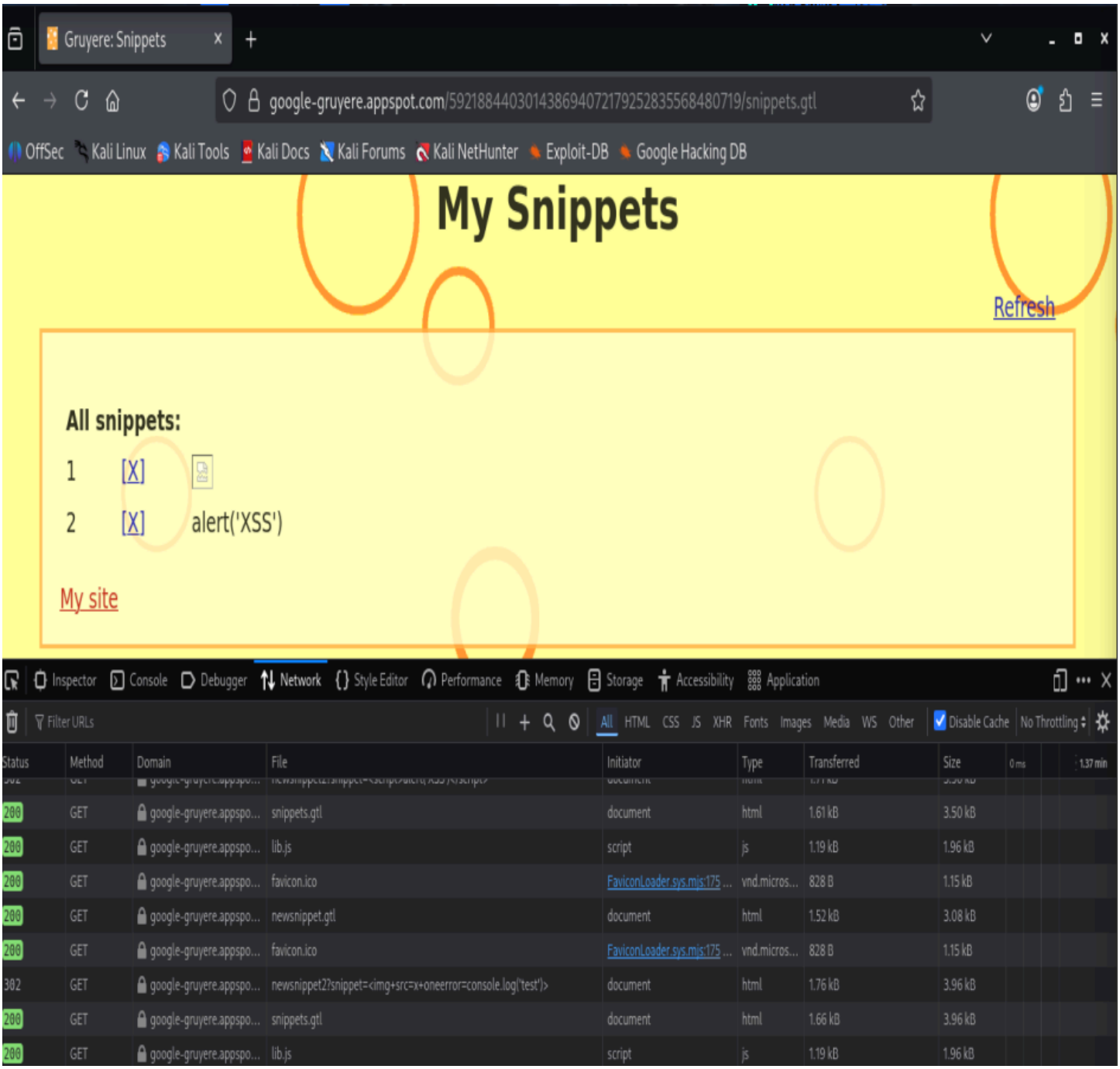
- Inconsistent rendering across browsers
- Potential layout vulnerabilities
- Outdated standards compliance

## Snippet Functionality Exposed (MEDIUM)

**Location:** /snippet.gtl, /newsnippet
**Risk Level:** **MEDIUM**

## Description

Snippet functionality allows user-generated content and may be vulnerable to XSS attacks.




## Impact

- Potential XSS through snippet content
- User input not properly sanitized
- Could lead to session hijacking

## Findings Summary

| # | Finding | Location | Risk | CVSS |
|---|---|---|---|---|
| 1 | Insecure Session Cookies | All pages | HIGH | 7.5 |
| 2 | Admin Panel Exposure | /admin | HIGH | 7.5 |
| 3 | Path Traversal | snippet.gtl | HIGH | 7.8 |
| 4 | Missing Security Headers | All pages | MEDIUM | 5.3 |
| 5 | X-XSS-Protection Disabled | All pages | MEDIUM | 5.0 |
| 6 | Snippet Functionality | /snippet | MEDIUM | 6.1 |
| 7 | Information Disclosure | Headers | LOW | 3.0 |
| 8 | Quirks Mode | All pages | LOW | 2.0 |

# Technical Details

## Nmap Command Used

```
# DNS Lookup
nslookup gruyere.appspot.com

# Basic Scan
nmap -sV -Pn 142.251.216.20

# Detailed Scan with Headers
nmap -sV -Pn -p 80,443 --script=http-headers 142.251.216.20
```

### DevTools Analysis

- **Network Tab**: Captured response headers, identified missing security headers
- **Application Tab**: Analyzed cookies, identified missing HttpOnly/Secure flags
- **Console Tab**: Identified Quirks Mode warning
- **Elements Tab**: Analyzed page structure

# Prioritized Remediation Plan

### Phase 1: Immediate - HIGH RISK

| Priority | Finding | Action |
|---|---|---|
| 1 | Insecure Session Cookies | Add HttpOnly/Secure flags, encrypt cookie data |
| 2 | Admin Panel Exposure | Implement authentication for /admin |
| 3 | Path Traversal | Validate and sanitize file paths |

### Phase 2: Short-term - MEDIUM RISK

| Priority | Finding | Action |
|---|---|---|
| 4 | Missing Security Headers | Add X-Frame-Options, CSP, HSTS |
| 5 | X-XSS-Protection | Set to 1; mode=block |
| 6 | Snippet Functionality | Add input validation, escape output |

### Phase 3: Long-term - LOW RISK

| Priority | Finding | Action |
|---|---|---|
| 7 | Information Disclosure | Remove debug headers |
| 8 | Quirks Mode | Add DOCTYPE declaration |

# Conclusion

The Google Gruyere application contains **multiple security vulnerabilities** ranging from low to high severity.

## Key Takeaways

- **Session management** is the most critical issue (cookies exposed, no security flags)
- **Admin panel** exposure provides unnecessary attack surface
- **Missing security headers** increase vulnerability to common attacks
- **Path traversal** could lead to sensitive file disclosure

## Overall Assessment

The application would **not be ready for production deployment** without addressing the high-risk findings identified in this assessment.